

NAME: THULASI.S

DATE:24.01.26

ROLL NO:241901118

EXPERIMENT 2

SECURITY PRINCIPLES

AIM:

To understand and observe the fundamental security principles such as confidentiality, integrity, availability, authentication, authorisation, and non-repudiation.

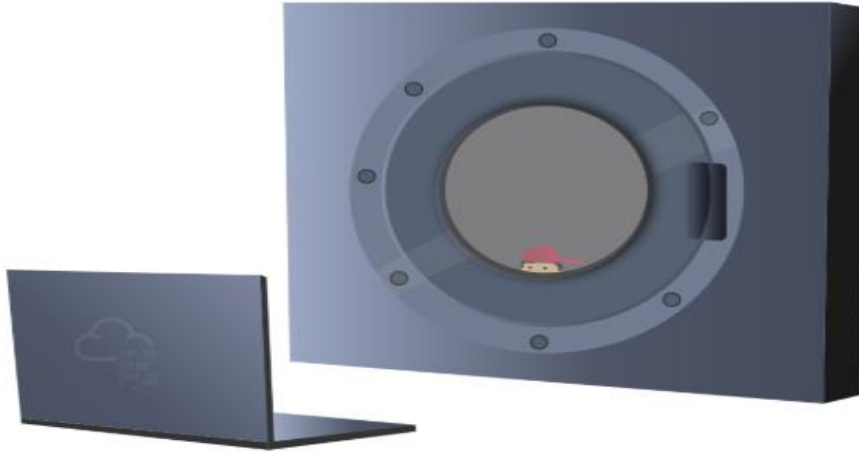
ALGORITHM:

1. Study the CIA Triad- Confidentiality, Integrity and Availability
2. Learn the concepts of Authentication, Authorisation, and Non-repudiation.
3. Go through the examples and explanations given for each principle.
4. Answer the questions/tasks in each section.
5. Verify the answers and complete the room.

Task 1 Introduction

Security has become a buzzword; every company wants to claim its product or service is secure. But is it?

Before we start discussing the different security principles, it is vital to know the adversary against whom we are protecting our assets. Are you trying to stop a toddler from accessing your laptop? Or are you trying to protect a laptop that contains technical designs worth millions of dollars? Using the exact protection mechanisms against toddlers and industrial espionage actors would be ludicrous. Consequently, knowing our adversary is a must so we can learn about their attacks and start implementing appropriate security controls.



It is impossible to achieve perfect security; no solution is 100% secure. Therefore, we try to improve our security posture to make it more difficult for our adversaries to gain access.

The objective of this room is to:

- Explain the security functions: Confidentiality, Integrity and Availability (CIA).
- Present the opposite of the security triad, CIA: Disclosure, Alteration, and Destruction/Denial (DAD).
- Introduce the fundamental concepts of security models, such as the Bell-LaPadula model.
- Explain security principles such as Defence-in-Depth, Zero Trust, and Trust but Verify.
- Introduce ISO/IEC 19248.
- Explain the difference between Vulnerability, Threat, and Risk.

Answer the questions below

Think how you would describe something as secure.

No answer needed

✓ Correct Answer

Task 2 CIA

View Site



Answer the questions below

Click on "View Site" and answer the five questions. What is the flag that you obtained at the end?

THM{CIA_TRIAD}

✓ Correct Answer





The security of a system is attacked through one of several means. It can be via the disclosure of secret data, alteration of data, or destruction of data.

- **Disclosure** is the opposite of confidentiality. In other words, disclosure of confidential data would be an attack on confidentiality.
- **Alteration** is the opposite of Integrity. For example, the integrity of a cheque is indispensable.
- **Destruction/Denial** is the opposite of Availability.

The opposite of the CIA Triad would be the DAD Triad: Disclosure, Alteration, and Destruction.

Consider the previous example of patient records and related systems:

- **Disclosure:** As in most modern countries, healthcare providers must maintain medical records' confidentiality. As a result, if an attacker succeeds in stealing some of these medical records and dumping them online to be viewed publicly, the health care provider will incur a loss due to this data disclosure attack.
- **Alteration:** Consider the gravity of the situation if the attacker manages to modify patient medical records. This alteration attack might lead to the wrong treatment being administered, and consequently, this alteration attack could be life threatening.
- **Destruction/Denial:** Consider the case where a medical facility has gone completely paperless. If an attacker manages to make the database systems unavailable, the facility will not be able to function properly. They can go back to paper temporarily; however, the patient records won't be available. This denial attack would stall the whole facility.

Protecting against disclosure, alteration, and destruction/denial is of utter significance. This protection is equivalent to working to maintain confidentiality, integrity and availability.

Protecting confidentiality and integrity to an extreme can restrict availability, and increasing availability to an extreme can result in losing confidentiality and integrity. Good security principles implementation requires a balance between the three.

Answer the questions below

The attacker managed to gain access to customer records and dumped them online. What is this attack?

✓ Correct Answer

A group of attackers were able to locate both the main and the backup power supply systems and switch them off. As a result, the whole network was shut down. What is this attack?

✓ Correct Answer

We have learned that the security triad is represented by Confidentiality, Integrity, and Availability (CIA). One might ask, how can we create a system that ensures one or more security functions? The answer would be in using security models. In this task, we will introduce three foundational security models:

[View Site](#)

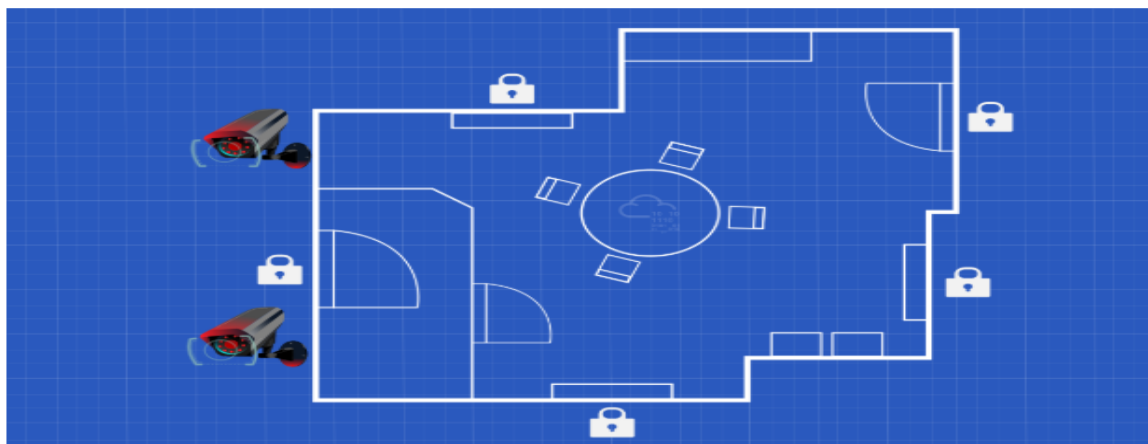
- Bell LaPadula Model
- The Biba Integrity Model
- The Clark Wilson Model

Answer the questions below

Click on "View Site" and answer the four questions. What is the flag that you obtained at the end?

✓ Correct Answer

Task 5 ● Defence in Depth



Defence-in-Depth refers to creating a security system of multiple levels; hence it is also called Multi-Level Security.

Consider the following analogy: you have a locked drawer where you keep your important documents and pricey stuff. The drawer is locked; however, do you want this drawer lock to be the only thing standing between a thief and your expensive items? If we think of multi-level security, we would prefer that the drawer be locked, the relevant room be locked, the main door of the apartment be locked, the building gate be locked, and you might even want to throw in a few security cameras along the way. Although these multiple levels of security cannot stop every thief, they would block most of them and slow down the others.

Answer the questions below

Make sure you have read the above.

No answer needed

✓ Correct Answer

Task 6 ● ISO/IEC 19249

The International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC) have created the ISO/IEC 19249. In this task, we will brush briefly upon ISO/IEC 19249:2017 *Information technology - Security techniques - Catalogue of architectural and design principles for secure products, systems and applications*. The purpose is to have a better idea of what international organizations would teach regarding security principles.

ISO/IEC 19249 lists five architectural principles:

Answer the questions below

Which principle are you applying when you turn off an insecure server that is not critical to the business?

2

✓ Correct Answer

Your company hired a new sales representative. Which principle are they applying when they tell you to give them access only to the company products and prices?

1

✓ Correct Answer

While reading the code of an ATM, you noticed a huge chunk of code to handle unexpected situations such as network disconnection and power failure. Which principle are they applying?

5

✓ Correct Answer

Task 7 ● Zero Trust versus Trust but Verify

Trust is a very complex topic; in reality, we cannot function without trust. If one were to think that the laptop vendor has installed spyware on the laptop, they would most likely end up rebuilding the system. If one were to mistrust the hardware vendor, they would stop using it completely. If we think of trust on a business level, things only become more sophisticated; however, we need some guiding security principles. Two security principles that are of interest to us regarding trust:

- Trust but Verify
- Zero Trust

Trust but Verify: This principle teaches that we should always verify even when we trust an entity and its behaviour. An entity might be a user or a system. Verifying usually requires setting up proper logging mechanisms; verifying indicates going through the logs to ensure everything is normal. In reality, it is not feasible to verify everything; just think of the work it takes to review all the actions taken by a single entity, such as internet pages browsed by a single user. This requires automated security mechanisms, such as proxy, intrusion detection, and intrusion prevention systems.

Zero Trust: This principle treats trust as a vulnerability, and consequently, it caters to insider-related threats. After considering trust as a vulnerability, zero trust tries to eliminate it. It is teaching indirectly, "never trust, always verify." In other words, every entity is considered adversarial until proven otherwise. Zero trust does not grant trust to a device based on its location or ownership. This approach contrasts with older models that would trust internal networks or enterprise-owned devices. Authentication and authorization are required before accessing any resource. As a result, if any breach occurs, the damage would be more contained if a zero trust architecture had been implemented.

Microsegmentation is one of the implementations used for Zero Trust. It refers to the design where a network segment can be as small as a single host. Moreover, communication between segments requires authentication, access control list checks, and other security requirements.

There is a limit to how much we can apply zero trust without negatively impacting a business; however, this does not mean that we should not apply it as long as it is feasible.

Answer the questions below

Make sure you have read the above.

No answer needed

✓ Correct Answer

Task 8 Threat versus Risk



There are three terms that we need to take note of to avoid any confusion.

- **Vulnerability:** Vulnerable means susceptible to attack or damage. In information security, a vulnerability is a weakness.
- **Threat:** A threat is a potential danger associated with this weakness or vulnerability.
- **Risk:** The risk is concerned with the likelihood of a threat actor exploiting a vulnerability and the consequent impact on the business.

Away from information systems, a showroom with doors and windows made of standard glass suffers a weakness, or vulnerability, due to the nature of glass. Consequently, there is a threat that the glass doors and windows can be broken. The showroom owners should contemplate the risk, i.e. the likelihood that a glass door or window gets broken and the resulting impact on the business.

Consider another example directly related to information systems. You work for a hospital that uses a particular database system to store all the medical records. One day, you are following the latest security news, and you learn that the used database system is not only vulnerable but also a proof of concept working exploit code has been released; the released exploit code indicates that the threat is real. With this knowledge, you must consider the resulting risk and decide the next steps.

We will cover threats and risks in detail in a separate room.

Answer the questions below

Make sure you have read the above.

No answer needed

✓ Correct Answer

Task 9 Conclusion

This room covered various principles and concepts related to security. By now, you should be very familiar with CIA and DAD and other terms such as authenticity, repudiation, vulnerability, threat, and risk. We visited three security models and the ISO/IEC 19249. We have covered different security principles such as defence in depth, trust but verify, and zero trust.

Finally, the Shared Responsibility Model is worth mentioning, especially with the increased reliance on cloud services. Various aspects are required to ensure proper security. They include hardware, network infrastructure, operating systems, applications, etc. However, customers using cloud services have different access levels depending on the cloud services they use. For example, an Infrastructure as a Service (IaaS) user has complete control (and responsibility) over the operating system.

On the other hand, a Software as a Service (SaaS) user has no direct access to the underlying operating system. Consequently, achieving security in a cloud environment necessitates both the cloud service provider and the user to do their parts. The Shared Responsibility Model is a cloud security framework to ensure that each party is aware of its responsibility.

Having finished the Security Principles room, you may proceed to the Intro to Cryptography room.

Answer the questions below

Make sure you have taken notes of all the key terms and acronyms we covered in this room.

No answer needed

✓ Correct Answer

RESULT:

The security principles were completed successfully.